



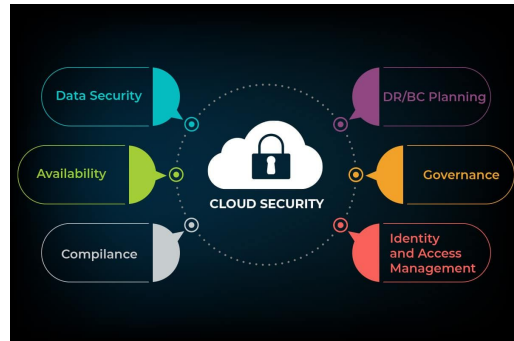
TEXAS A&M UNIVERSITY

Department of Computer
Science & Engineering

CSCE 412: Cloud Computing

Module 8

In this series, we will be covering the ways providers protect customer data, physical security measures, and standards in protecting customer and user data.



Providers go to great lengths to safeguard customer data through a multi-faceted approach. This includes stringent physical security measures at their data centers, employing sophisticated surveillance, access controls, and biometric authentication to ensure that only authorized personnel can access sensitive information. Additionally, providers adhere to rigorous industry standards and compliance frameworks, such as GDPR, HIPAA, and ISO 27001, to uphold the highest levels of data protection. Encryption protocols are also implemented to secure data both in transit and at rest, providing an additional layer of defense against unauthorized access. By combining these measures, cloud service providers create a fortified environment where customer and user data remains shielded from potential threats or breaches.



What do providers do to protect my data?

- Cryptography
- Balance performance with security
- Symmetric and Asymmetric Encryption
- AES (Advanced Encryption Standard)
- RSA (Rivest–Shamir–Adleman)

Providers employ a range of robust measures to protect cloud data, including:

1. Cryptography: Providers leverage cryptographic techniques to secure data. This involves encoding information using complex algorithms and cryptographic keys, rendering it unintelligible to unauthorized parties.

2. Balancing Performance with Security: Providers carefully calibrate the level of encryption and security measures to ensure that data remains well-protected without compromising system performance or responsiveness.

3. Symmetric and Asymmetric Encryption: Providers utilize both symmetric and asymmetric encryption. Symmetric encryption employs a single key for both encryption and decryption, while asymmetric encryption uses a pair of keys (public and private) for these processes.

4. AES (Advanced Encryption Standard): AES is a widely adopted symmetric-key encryption algorithm used to secure data. It operates on fixed-size blocks of data and supports key lengths of 128, 192, or 256 bits, providing a high level of security.

5. RSA (Rivest–Shamir–Adleman): RSA is a prominent asymmetric-key encryption algorithm. It employs a public key for encryption and a private key

for decryption. RSA is commonly used for tasks like secure communication, digital signatures, and key exchange protocols.

By skillfully employing these cryptographic methods and encryption standards, cloud service providers fortify the security of data stored and transmitted within their platforms. This ensures that sensitive information remains confidential and well-protected against unauthorized access or interception.



What is stopping someone from walking into a data center and accessing physical systems or drives?

- Physical Security Controls
 - Access control vestibule
- Secure Area
 - Air Gap
 - Physical separation between devices or between networks
- Secure Data Destruction
 - Degausser
 - A pulverizer or an incineration

Several robust physical security measures are in place to prevent unauthorized access to data centers:

1. Physical Security Controls: Data centers implement a combination of security measures, including surveillance cameras, motion detectors, and alarms, to monitor and control access to the facility.

2. Access Control Vestibule: Many data centers employ an access control vestibule, which is a small, secure area that acts as a buffer zone. It requires proper authentication before allowing entry into the main data center space.

3. Secure Area: The data center itself is a highly secure area, often equipped with reinforced walls, locked doors, and biometric or keycard access systems to ensure only authorized personnel can enter.

4. Air Gap: An air gap is a physical separation between systems or networks, ensuring that they are not connected in any way. This prevents unauthorized access or transmission of data between devices.

5. Physical Separation between Devices or Networks: Devices and networks within the data center are physically segregated, limiting the potential for unauthorized access or interference between systems.

6. Secure Data Destruction: When it comes time to decommission equipment or dispose of data-containing devices, secure data destruction methods are employed to ensure that sensitive information cannot be retrieved.

7. Degausser: A degausser is a device that uses a strong magnetic field to erase data from magnetic storage media, rendering it irretrievable.

8. Pulverizer or Incineration: In cases where physical drives or devices need to be disposed of, some data centers use methods like pulverizing or incinerating to completely destroy them, preventing any possibility of data recovery.

These combined physical security measures create a formidable barrier against unauthorized access to data center facilities and equipment. This ensures that only authorized personnel with the necessary credentials and permissions can access the physical systems or drives within the data center.



Is there a minimum standard or level of compliance that providers are required to follow?

- **GDPR**
 - General Data Protection Regulation
 - Rules and regulations that allow someone in the EU to control what happens with their private information.
 - Name, address, phone number, medical information, or anything else that would be specific to you.
 - Allows you to understand where your information is stored and prevents information from being exported outside of the European Union. Control of this data back into your hands.

The General Data Protection Regulation (GDPR) is a comprehensive data protection and privacy regulation that was implemented by the European Union (EU) in May 2018. It replaced the Data Protection Directive of 1995 and is designed to harmonize data protection laws across EU member states, as well as to provide greater privacy rights and protection for individuals within the EU.

Key components of the GDPR include:

- 1. Scope and Applicability:** The GDPR applies to organizations, both within and outside the EU, that process the personal data of EU residents. This means that businesses and entities around the world must comply if they handle EU citizens' data.
- 2. Rights of Data Subjects:** The regulation grants individuals, or "data subjects," a range of rights over their personal data. These rights include the right to access, correct, and delete their data, as well as the right to know how their data is being used.
- 3. Data Protection Officers (DPOs):** Certain organizations are required to appoint a Data Protection Officer, whose role is to oversee data protection activities and ensure compliance with the GDPR.
- 4. Data Breach Notification:** Organizations are required to notify the appropriate authorities and affected individuals within a specific timeframe if they experience a

data breach that poses a risk to individuals' rights and freedoms.

5. Accountability and Governance: The GDPR places an emphasis on organizations demonstrating compliance with the regulation. This includes implementing appropriate security measures, conducting data protection impact assessments, and maintaining records of processing activities.

6. Penalties and Fines: The GDPR introduces significant penalties for non-compliance. Organizations that fail to meet the requirements of the regulation can face fines of up to €20 million or 4% of their global annual revenue, whichever is higher.

7. International Data Transfers: The GDPR sets out strict rules for the transfer of personal data outside the EU. Organizations must ensure that adequate safeguards are in place when transferring data to countries that do not have an "adequacy decision" from the EU.

The GDPR represents a significant shift in data protection and privacy laws, with a strong emphasis on transparency, accountability, and individual rights. It has had a far-reaching impact on how organizations worldwide handle and protect personal data, and it continues to be a key consideration for businesses operating in the digital age.



Is there a minimum standard or level of compliance that providers are required to follow?

- PCI-DSS
 - Payment Card Industry Data Security Standard
 - Applies to any organization that collects and stores credit card details.

The Payment Card Industry Data Security Standard (PCI-DSS) is a set of security standards established to ensure the secure handling of payment card information. It was developed jointly by major credit card companies such as Visa, MasterCard, American Express, Discover, and JCB. PCI-DSS applies to any organization, regardless of size or location, that processes, transmits, or stores credit card information.

Key components and requirements of PCI-DSS include:

- 1. Build and Maintain a Secure Network:** This involves installing and maintaining a firewall configuration to protect cardholder data and not using vendor-supplied defaults for system passwords.
- 2. Protect Cardholder Data:** Organizations must take measures to encrypt the transmission of cardholder data across public networks and ensure that sensitive information is stored securely.
- 3. Maintain a Vulnerability Management Program:** This includes regularly updating anti-virus software, as well as developing and maintaining secure systems and applications.
- 4. Implement Strong Access Control Measures:** Access to cardholder data should be restricted based on business need-to-know, and a unique ID should be assigned to each person with computer access.

5. Regularly Monitor and Test Networks: Organizations should track and monitor all access to network resources and cardholder data, as well as conduct regular security testing and vulnerability assessments.

6. Maintain an Information Security Policy: Establishing and maintaining a security policy that addresses information security for employees and contractors is essential.

7. Maintain a Vulnerability Management Program: This includes regularly updating anti-virus software, as well as developing and maintaining secure systems and applications.

8. Implement Strong Access Control Measures: Access to cardholder data should be restricted based on business need-to-know, and a unique ID should be assigned to each person with computer access.

9. Regularly Monitor and Test Networks: Organizations should track and monitor all access to network resources and cardholder data, as well as conduct regular security testing and vulnerability assessments.

10. Maintain an Information Security Policy: Establishing and maintaining a security policy that addresses information security for employees and contractors is essential.

Compliance with PCI-DSS helps organizations protect sensitive payment card information from security breaches and unauthorized access. It not only safeguards the financial transactions of customers but also helps build trust and confidence in the organization's ability to handle payment data securely. Non-compliance can result in penalties, fines, and potential legal consequences for businesses.



Is there a minimum standard or level of compliance that providers are required to follow?

- NIST Cybersecurity Framework (CSF)
 - Framework Core. This includes identifying, protecting, detecting, responding, and recovering.
 - Framework Implementation Tiers. This is the section where an organization will understand exactly what their approach will be to cybersecurity, and what tools and processes need to be in place to manage the risks that are identified.
 - Framework Profile, where policies, guidelines, and standards are compared to the implementations that are based on the framework core.

The National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) is a comprehensive set of guidelines, best practices, and standards designed to enhance cybersecurity measures within organizations. Developed by NIST, a division of the U.S. Department of Commerce, the CSF provides a flexible framework that can be adapted to the specific needs and risk profiles of various industries and sectors.

The CSF is built on five core functions:

- 1. Identify:** This function focuses on understanding and managing cybersecurity risks. It involves identifying critical assets, understanding business dependencies, and establishing risk management processes. By gaining a clear understanding of the organization's cybersecurity posture, it becomes possible to prioritize efforts effectively.
- 2. Protect:** The Protect function involves implementing safeguards and controls to ensure the security of critical assets and data. This includes measures such as access controls, data encryption, secure configurations, and employee training. By fortifying the organization's defenses, it becomes more resilient to cyber threats.
- 3. Detect:** This function involves establishing mechanisms for timely identification of cybersecurity incidents. It encompasses continuous monitoring, intrusion detection systems, and other tools and processes that help in the early detection of anomalies or breaches.

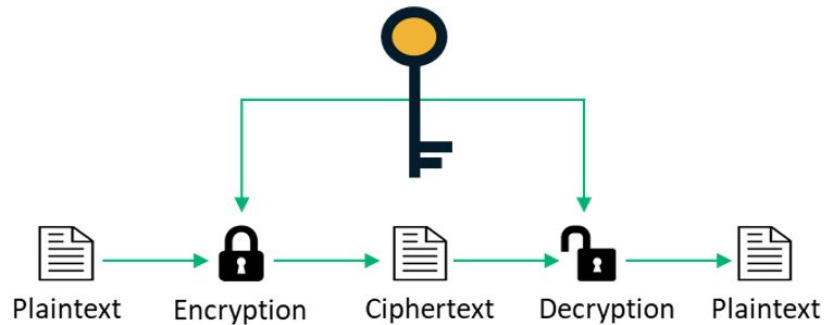
4. Respond: In the event of a cybersecurity incident, the Respond function outlines steps to contain the impact, mitigate the damage, and recover swiftly. This includes incident response planning, communication strategies, and coordination with relevant stakeholders.

5. Recover: The Recover function focuses on restoring normal operations and services after a cybersecurity incident. This involves implementing strategies for system restoration, data recovery, and resilience planning to ensure business continuity.

The CSF is designed to be adaptable to various industries, sectors, and organizational sizes. It provides a common language and set of practices for organizations to manage and reduce cybersecurity risks effectively. While it does not provide a one-size-fits-all solution, the CSF serves as a flexible and scalable framework that empowers organizations to enhance their cybersecurity posture and respond effectively to the evolving threat landscape.

Symmetric Encryption

Single key sent over a secure channel



Symmetric encryption is a cryptographic technique that uses a single shared key for both the encryption and decryption of data. In this method, the same key is used to both scramble (encrypt) and unscramble (decrypt) the information. This key is kept confidential and secure, as it is essential for the process to work effectively. One of the primary advantages of symmetric encryption is its efficiency, as it tends to be faster and less computationally intensive compared to its asymmetric counterpart. However, a significant challenge in using symmetric encryption lies in securely transmitting the key itself, as it must be sent over a secure channel to ensure it doesn't fall into the wrong hands.



Symmetric Encryption

- There's a single shared key that's used for encryption and decryption.
- Faster and functions without a lot of overheads on network or CPU resources.
- It doesn't scale very well because the secret key must not be lost or shared with unauthorized parties, or else they can read the message.
- Improper maintenance of the key hierarchy can lead to key reconstruction by an attacker.

Four concepts of Symmetric Encryption:

1. Single Shared Key: In symmetric encryption, there exists a single secret key that is employed for both the encryption and decryption processes. This means that the same key that is used to convert plaintext into ciphertext is also used to reverse the process and obtain the original message. It is crucial to keep this key confidential and secure, as it is the linchpin of the encryption system.

2. Efficiency and Low Overheads: Symmetric encryption tends to be faster and less resource-intensive compared to asymmetric encryption. This efficiency arises from the simplicity of using a single key for both encryption and decryption. This results in fewer computational operations, making it a preferred choice for scenarios where speed and performance are critical.

3. Scalability Challenges: One of the primary challenges with symmetric encryption lies in the distribution and management of the secret key. Since the same key is used for both encryption and decryption, it is vital to ensure that the key is not lost or compromised. If it falls into unauthorized hands, they can easily decrypt any messages encrypted with that key. This makes managing keys at scale a complex endeavor.

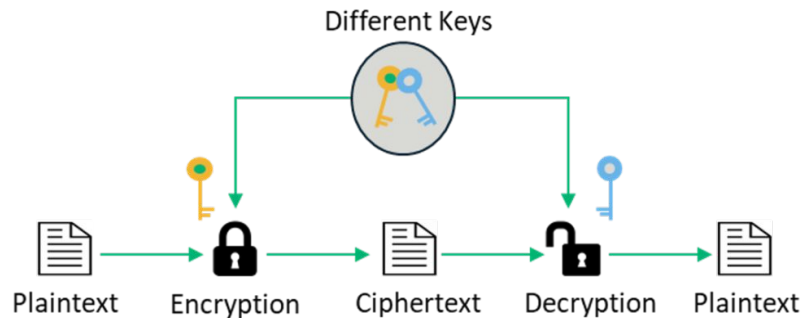
4. Key Hierarchy Maintenance: Proper maintenance of the key hierarchy is crucial for ensuring the security of symmetric encryption. If the key management process is not executed correctly, it may inadvertently reveal information that can be used to

reconstruct the key. This scenario is a significant concern, as it could potentially allow an attacker to gain unauthorized access to encrypted data.

Overall, symmetric encryption is a powerful tool for securing data, but it requires careful management of keys to maintain its effectiveness and security.

Asymmetric Encryption

A pair of related keys, one public, one private.



Asymmetric encryption, also known as public-key cryptography, operates on the principle of using a pair of mathematically related keys for encryption and decryption. These keys are composed of a public key and a private key. The public key is freely distributed and accessible to anyone, while the private key is kept strictly confidential and known only to the owner. When a sender wants to send an encrypted message to a recipient, they use the recipient's public key to encrypt the message. The recipient, in turn, uses their private key to decrypt the message. This unique dual-key system provides a secure means of communication without the need for both parties to share a common secret key.



Asymmetric Encryption

- It involves the use of two mathematically related keys. The public key (the one that's known to everybody) and the private key (which is only known by you) are required for encrypting and decrypting the message.
- The private key cannot be derived from the public key.
- The public key is used by others to encrypt the messages they send to you, but to decrypt and read these messages, one needs access to the private key.
- Higher security and higher overhead.

Four concepts of Asymmetric Encryption:

1. Use of Two Mathematically Related Keys: Asymmetric encryption relies on a pair of keys that are mathematically linked. These keys are known as the public key and the private key. The public key is openly accessible to anyone, while the private key is kept confidential and known only to the owner. These keys work together in a way that allows data to be encrypted with one key and decrypted with the other.

2. Uniqueness of Private Key: It is computationally infeasible to derive the private key from the corresponding public key. This means that even if someone has access to the public key, they cannot reverse-engineer it to obtain the private key. The private key remains a closely guarded secret and is essential for decrypting messages encrypted with the corresponding public key.

3. Role of Public and Private Keys: The public key is utilized by others to encrypt messages intended for you. Once a message is encrypted with your public key, only your private key can decrypt and reveal the original content. This ensures that only the intended recipient, who possesses the private key, can access the message.

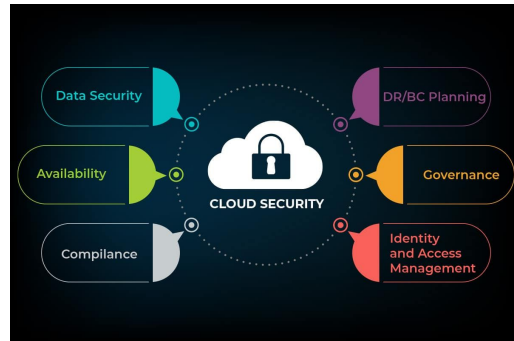
4. Security and Overhead Considerations: Asymmetric encryption provides a higher level of security compared to symmetric encryption due to the unique key pair structure. However, it also entails higher computational overhead because the algorithms involved are more complex. This can lead to slower processing times and increased resource utilization, making it less efficient for certain tasks.

In summary, asymmetric encryption employs a pair of mathematically related keys to provide a high level of security in data communication. The public key is used for encryption by others, while the private key is kept secret and used for decryption. While offering strong security, it also comes with greater computational demands.

In this module, we learned about how providers protect data using modern cryptographic techniques, physical measures for protecting equipment, and regulations or standards that set the bar for securing systems.

Learn more at:

<https://www.nist.gov/cybersecurity>



Cloud providers implement a range of robust measures to protect user data:

- 1. Encryption:** They employ advanced encryption protocols to secure data both in transit and at rest. This ensures that even if intercepted, the data remains unintelligible without the correct decryption key.
- 2. Access Controls:** Providers implement strict access control mechanisms, ensuring that only authorized personnel and applications can access and modify user data. This involves the use of authentication and authorization processes.
- 3. Physical Security:** Data centers are equipped with stringent physical security measures, including biometric access controls, surveillance systems, and restricted access areas. This prevents unauthorized individuals from physically accessing the servers and storage devices.
- 4. Redundancy and Backups:** Cloud providers often implement redundant systems and regular data backups to safeguard against hardware failures, data corruption, or other unforeseen incidents. This ensures data availability and integrity.
- 5. Compliance and Certifications:** Many cloud providers adhere to industry-specific compliance standards and undergo third-party audits to validate their security practices. This provides users with assurance that the provider meets rigorous security requirements.

Overall, cloud providers prioritize the security and privacy of user data, implementing a multi-layered approach to protect against various threats and vulnerabilities. These measures collectively work to ensure that user data remains secure and accessible only to authorized parties.



TEXAS A&M UNIVERSITY

Department of Computer
Science & Engineering

CSCE 412: Cloud Computing

Module 8